

Vendor Risk Management Policy

Policy VR-006 - Vendor Assessment and Risk Acceptance

Organization: Northstar Financial Services (NFS)

Classification: INTERNAL - TRAINING

Effective date: September 2026

1. Risk domains

Vendor assessments cover Security, Privacy, Legal/Contractual, Operational Resilience, Financial/Commercial and AI Governance where applicable.

2. Overall rating

Overall risk is LOW, MEDIUM or HIGH. A single unresolved mandatory-control failure may drive the overall rating to HIGH even if other domains are satisfactory.

3. Decision outcomes

APPROVE

All mandatory controls satisfied; residual risks accepted by authorized owners.

CONDITIONAL APPROVAL

No prohibited control failure, but remediation or contractual conditions are required before or shortly after go-live.

REJECT

One or more mandatory controls cannot be met, evidence is materially unreliable, or residual risk exceeds NFS tolerance.

4. Missing evidence

Missing evidence must be recorded as UNKNOWN. It must not be converted to PASS by assumption. Material UNKNOWN findings may prevent approval.

5. Risk acceptance

High residual risk requires explicit acceptance by the accountable executive risk owner. Procurement or an AI system cannot accept High risk on the owner's behalf.

6. Review frequency

Critical vendors are reviewed annually and following material security incidents, major architecture changes or significant subprocessor changes.